

Enumeracion de FTP

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

FTP (puerto 21) es un protocolo de transferencia de ficheros anterior a la web. Muchas instalaciones dejan habilitado el login 'anonymous' (usuario anonymous, cualquier password) por comodidad o por defecto. Si esta activo, entras sin credenciales y puedes listar, descargar, y a veces subir ficheros segun los permisos del share.

El login anonimo es una funcionalidad legitima de FTP para descargas publicas, pero cuando se deja activo sobre un share que contiene ficheros sensibles (backups, configs, notas), se convierte en una fuga de informacion gratuita. Es la misma logica que la sesion nula de smb-enum aplicada a FTP.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Siempre que el recon muestre el puerto 21 abierto. Es de las comprobaciones mas baratas: un intento de login anonimo tarda segundos.

Cómo identificarla

- Puerto 21 abierto en el escaneo de puertos.
- El banner de nmap/ftp menciona 'Anonymous FTP login allowed'.
- Login con usuario anonymous aceptado.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Conecta con usuario anonymous y password vacia o cualquiera; si el login es aceptado, lista el contenido.

Evidencia esperada: Un login exitoso (230 Login successful) seguido de un listado de ficheros/directorios confirma acceso anonimo.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.

3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

ftp \$IP

Objetivo y contexto: Conecta al servicio FTP para probar el login anonimo de forma interactiva. Cuando pida usuario, prueba anonymous; password, cualquier cosa o vacia.

Resultado esperado: '230 Login successful' confirma acceso anonimo. Un ls/dir tras entrar te muestra el contenido del share; get descarga ficheros.

Anatomía de los payloads

La primera prueba es ftp \$IP. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Un login exitoso (230 Login successful) seguido de un listado de ficheros/directorios confirma acceso anonimo.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Prueba login anonimo primero; es gratis y muy comun que funcione en labs.
- Si entra, lista y descarga TODO lo accesible; busca configs, backups, claves SSH o notas con credenciales.
- Comprueba tambien permisos de escritura (STOR): un FTP anonimo con escritura permite subir un webshell si el mismo directorio se sirve por HTTP.
- Cualquier credencial encontrada -> pruebala en otros servicios (cracking si esta hasheada, reuse si esta en claro).

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- El servidor rechaza el usuario anonymous y no tienes ninguna otra credencial que probar.
- El share anonimo esta vacio o solo contiene ficheros publicos sin valor.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

FTP suele permitir login anónimo; si lo hace, listas y descargas ficheros sin credenciales, y a veces hasta escribes. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook \(ftp-enum\)](#)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.